

# Audit-Tail Final Report

Project: **vulnerable-invoice-service** · Stage 4 (aggregate) · Generated 2026-06-23 · Branch: `fix/depSCAN-20260623-061718`

## Executive summary

- 9 dependencies scanned · 28 CVEs before remediation · 18 CVEs cleared by this PR.
- Supply-chain:** **CLEARED** — typosquat removed, untrusted HTTP repo removed.
- Licenses:** 1 violation open (GPL-2.0 on mysql-connector-java — MAJOR\_REVIEW).
- Remaining:** 10 CVEs in 4 dependencies require human follow-up (3 MAJOR\_REVIEW, 2 INEFFECTIVE).
- Gate verdict:** **CONDITIONAL PASS** — CRITICAL + Log4Shell CVEs cleared; remaining open items tracked as issues.

## Stage 1 — Dependency Scan

| Metric              | Before | After |
|---------------------|--------|-------|
| Total CVEs          | 28     | 10    |
| CRITICAL CVEs       | 6      | 0     |
| HIGH CVEs           | 11     | 7     |
| MEDIUM CVEs         | 9      | 3     |
| Supply-chain alerts | 2      | 0     |

Scan date: 2026-06-23 · Scanner: OWASP Dependency-Check 12.2.2 · NVD data: 2026-06-13

## Stage 2 — Risk Scoring

| Band            | Before | After |
|-----------------|--------|-------|
| <b>CRITICAL</b> | 1      | 0     |
| <b>HIGH</b>     | 6      | 4     |
| <b>MEDIUM</b>   | 3      | 2     |
| <b>LOW</b>      | 0      | 0     |

Scoring weights: CVE severity 50% · Exposure 30% · Business criticality 20%

## Stage 3 — Auto-Remediation

| Coordinate                                                                          | Change                   | CVEs Cleared          | Result      |
|-------------------------------------------------------------------------------------|--------------------------|-----------------------|-------------|
| com.fastxml.jackson.core:jackson-databind                                           | REMOVED (typosquat)      | Supply-chain CRITICAL | <b>DONE</b> |
| <a href="http://insecure-mirror.example.net">http://insecure-mirror.example.net</a> | REMOVED (untrusted repo) | Supply-chain HIGH     | <b>DONE</b> |

|                                             |                        |                                                                               |              |
|---------------------------------------------|------------------------|-------------------------------------------------------------------------------|--------------|
| org.apache.logging.log4j:log4j-core         | 2.14.1 → 2.17.1        | CVE-2021-44228 (10.0), CVE-2021-45046 (9.0), CVE-2021-44832, CVE-2021-45105   | EFFECTIVE    |
| org.apache.logging.log4j:log4j-api          | 2.14.1 → 2.17.1        | CVE-2021-44228, CVE-2021-45046 (lockstep)                                     | EFFECTIVE    |
| com.fasterxml.jackson.core:jackson-databind | 2.9.8 → 2.18.4         | 8 CVEs incl. CVE-2019-14379 (9.8), CVE-2019-14540 (9.8), CVE-2019-14892 (9.8) | EFFECTIVE    |
| commons-io:commons-io                       | 2.4 → 2.14.0           | CVE-2021-29425 (4.8), CVE-2024-47554 (4.3)                                    | EFFECTIVE    |
| org.apache.commons:commons-lang3            | 3.4 → 3.17.0           | CVE-2025-48924 persists                                                       | INEFFECTIVE  |
| mysql:mysql-connector-java                  | 8.0.30 → 8.0.33        | CVE-2023-22102 persists (fix needs 8.2.0+)                                    | INEFFECTIVE  |
| com.google.guava:guava                      | 24.1.1-jre (unchanged) | CVE-2023-2976, CVE-2020-8908                                                  | MAJOR_REVIEW |

**Build verification:** `mvn clean test` — **PASS** (2 tests, 0 failures)

**Pre-existing gate failure:** `mvn verify` fails JaCoCo 80% line-coverage check — pre-existing condition, not caused by this PR.

## Stage 4 — Merge Gate

**CONDITIONAL PASS.** All CRITICAL and Log4Shell CVEs have been cleared. The following items remain open and are tracked as issues on this PR:

| Item                     | Type         | CVE/Issue                    | Action                    |
|--------------------------|--------------|------------------------------|---------------------------|
| guava 24 → 32 major bump | MAJOR_REVIEW | CVE-2023-2976, CVE-2020-8908 | See tracking issue        |
| mysql CVE-2023-22102     | INEFFECTIVE  | Requires 8.2.0+              | See tracking issue        |
| log4j 2.17.1 → 2.26.0    | MAJOR_REVIEW | CVE-2026-34479/34480/34477   | See tracking issue        |
| mysql GPL-2.0 license    | License      | —                            | Human decision required   |
| Test coverage < 80%      | Pre-existing | —                            | Not introduced by this PR |

## Human Follow-Ups Required

- Upgrade guava 24.1.1-jre → 32.0.0-jre** — test for API compatibility (Files.createTempDir removed, beta annotations changed).
- Upgrade mysql-connector-java 8.0.33 → 8.2.0+** — evaluate new coordinate `com.mysql:mysql-connector-j`.
- Upgrade log4j 2.17.1 → 2.26.0** — clear CVE-2026-34479, CVE-2026-34480, CVE-2026-34477.
- Resolve mysql GPL-2.0 license** — obtain Oracle commercial exception or migrate to MariaDB Connector/J (LGPL-2.1).
- Increase test coverage above 80%** — JaCoCo gate fails at `verify` phase; pre-existing condition.

Machine-readable sources: `depscan-report.json`, `depscan-risk-report.json`. Generated by the Dependency & Supply-Chain Plugin — Stage 4 (Audit Trail).